

Customer Data Handling Policy

Nova Insurance Group | Policy Document NIG-POL-CDH-003

1. Purpose

Customer data is among Nova Insurance Group's most sensitive and commercially critical assets. This policy defines how customer data must be collected, stored, accessed, shared and disposed of throughout its lifecycle. It supplements the Data Privacy Guideline (NIG-GDL-DPR-002) with operational rules specific to customer-facing and customer-data-intensive activities.

2. What Constitutes Customer Data

Customer data encompasses all information held by or on behalf of Nova Insurance Group that relates to current, former or prospective customers. This includes but is not limited to:

Category	Examples
Identification Data	Full name, date of birth, national ID number, passport number, tax ID.
Contact Data	Address, email address, telephone number, communication preferences.
Policy Data	Policy numbers, coverage details, premium amounts, renewal dates, endorsements.
Claims Data	Claim numbers, incident descriptions, loss amounts, claims correspondence, medical reports.
Financial Data	Bank account details, credit card data, payment history, premium payment records.
Health Data	Medical histories, diagnoses, prescriptions (where applicable to life/health lines).
Behavioural Data	Telematics data, online account activity, call recordings, chatbot transcripts.
Third-Party Data	Data about third parties (e.g., beneficiaries, accident counterparties) provided by or about customers.

3. Access Controls

Access to customer data is granted on a strict need-to-know basis and is governed by the Role-Based Access Control (RBAC) framework maintained by IT Security. The following rules apply:

- All access to customer data systems requires multi-factor authentication (MFA).
- Access rights must be reviewed by Line Managers every 90 days; dormant accounts are deactivated.
- Bulk downloads or exports of customer records require written approval from the relevant department head and IT Security.
- Customer data must not be stored on personal devices, portable drives or unmanaged cloud storage.
- Temporary access granted for specific projects must be revoked within 5 business days of project completion.
- Audit logs of all customer data access are retained for a minimum of 3 years.

4. Prohibition on Use with Public AI Tools

Under no circumstances may customer data — in any form, whether full records, partial excerpts, screenshots, or verbally paraphrased content — be entered into, uploaded to or submitted via a public AI tool or any AI service not listed on the Approved Tools Register.

This prohibition extends to:

- Customer names, policy numbers or any combination that could identify an individual.
- Claims descriptions or incident narratives, even when the customer name is removed.
- Financial account numbers, premium amounts or payment data.
- Medical or health information in any format.
- Structured exports (CSV, Excel) containing customer records.
- Any data that could — alone or in combination — re-identify an individual (pseudonymous data).

Employees who need AI assistance for tasks involving customer data must use only internally approved and deployed AI tools. Contact the IT Service Desk to request access to approved AI tools (Ticket category: AI Tool Access).

5. Data Sharing and Third-Party Transfers

Customer data may only be shared with third parties in accordance with the following conditions:

- A Data Processing Agreement (DPA) or Data Sharing Agreement is in place and signed.
- The transfer has been reviewed and approved by the DPO.
- The receiving party is listed in the Records of Processing Activities (RoPA).
- Transfers outside the EEA comply with Chapter V of the GDPR (adequacy decision, SCCs, etc.).

Sharing customer data verbally (e.g., by phone) with unverified parties is prohibited. Always verify the identity of the requesting party before disclosing any customer information.

6. Data Retention and Disposal

Data Category	Minimum Retention	Maximum Retention	Disposal Method
Policy Records	Duration of contract	10 years post-expiry	Secure deletion
Claims Records	Duration of claim	10 years post-settlement	Secure deletion
Health / Medical Data	As required by law	7 years post-claim closure	Certified destruction
Call Recordings	N/A	90 days (default)	Automated purge
Marketing Data	Consent valid	Until opt-out + 30 days	Automated purge

7. Incident Reporting

Any suspected mishandling of customer data — including accidental disclosure, loss of device containing customer data, or suspicion that customer data has been entered into an unauthorised system — must be reported immediately to:

- IT Security Hotline: +49 711 900 2911 (24/7)
- DPO email: dpo@nova-insurance.eu
- Incident Portal: <https://intranet.nova-insurance.eu/security/incident>

Early reporting is critical. Employees who promptly report incidents will not face disciplinary action solely for reporting. Deliberate concealment of a data incident is a serious disciplinary offence.